INFORME TÉCNICO DE RESOLUCIÓN CTF

ORION-7

Gobuster · Descubrimiento de recursos web

Integrante: Felipe Segura

Asignatura: Ciberseguridad Avanzada

Docente: Rodrigo Ledezma

Fecha: 3 de noviembre de 2026

Resultado documentado

La resolución registra los tres fragmentos y la FLAG final; no se conservaron capturas ni salidas originales de consola.

Elaborado a partir de la resolución y las evidencias disponibles del desafío.

2. Introducción

El objetivo de ORION-7 es encontrar tres fragmentos ocultos en un servidor web y unirlos en una FLAG. El alcance se restringe al servicio local http://localhost:8080.

3. Análisis inicial

El enunciado entrega un laboratorio Docker y advierte que existen señuelos. Se planteó enumerar directorios y archivos desde HTTP, revisar respuestas y repetir la búsqueda en las rutas descubiertas. No se inspeccionó el contenido del contenedor para elaborar este informe.

4. Herramientas utilizadas

Gobuster: prueba nombres de un diccionario contra el servidor. Se eligió para localizar rutas y archivos no enlazados.

curl: permite revisar cabeceras y cuerpos de respuesta, y enviar un User-Agent específico.

sed, tr y base64: extraen la nota del respaldo, eliminan retornos de carro y decodifican la pista.

5. Metodología de resolución

Paso 1. Enumeración inicial

```
gobuster dir -u http://localhost:8080 -w /usr/share/wordlists/dirb/common.txt -x
    txt,html,json,bak,old,zip -t 20 -o gobuster-archivos.txt
```

-u indica el objetivo; -w, el diccionario; -x, las extensiones; -t, los hilos; -o, la salida. Se usó common.txt de dirb según la resolución. Se revisaron robots.txt, /archive/ y /personal/ con curl -i y se repitió Gobuster dentro de los directorios descubiertos.

Paso 2. Interpretación de respuestas y respaldo

```
curl -i http://localhost:8080/archive/
curl -i http://localhost:8080/archive/config.bak
curl -s http://localhost:8080/archive/config.bak | sed -n 's/^nota_operador *= *//p' | tr -d
    '\r' | base64 -d
```

El HTML del 403 de /archive/ contenía n4d4. El respaldo config.bak contenía una nota Base64 que aportó 3st4 y la indicación necesaria para continuar con el agente SENTINEL/2.1. Un 403 del directorio no implicaba que todos sus archivos estuvieran bloqueados.

Paso 3. Continuación con el User-Agent indicado

```
curl -i -A 'SENTINEL/2.1' http://localhost:8080/core/
gobuster dir -u http://localhost:8080/core/ -a 'SENTINEL/2.1' -w
    /usr/share/wordlists/dirb/common.txt -x txt,html,json,bak,old,zip -t 20 -o
    gobuster-core.txt
curl -i -A 'SENTINEL/2.1' http://localhost:8080/core/console/
```

-a en Gobuster y -A en curl configuran User-Agent. Se repitió la enumeración dentro de /core/console/ y se obtuvo 0cult0. Los fragmentos se reunieron en el orden documentado.

6. Evidencias

La evidencia conservada es resolucion.md. El siguiente resumen reproduce sus hallazgos; no es una salida nueva del servidor ni una captura original:

```
Recurso / condición                          Fragmento
/archive/ (cuerpo HTML del 403)              n4d4
/archive/config.bak (nota Base64)            3st4
/core/console/ + User-Agent SENTINEL/2.1     0cult0
```

Los archivos gobuster-archivos.txt, gobuster-core.txt y las salidas guardadas con tee aparecen en los comandos documentados, pero no están en la carpeta entregada. Falta adjuntar sus salidas o capturas para respaldar visualmente el recorrido.

7. Uso de pistas

Se aprovecharon las pistas del propio servicio: contenido del 403, nota Base64 y User-Agent SENTINEL/2.1. No hay registro de pistas escalonadas solicitadas al organizador. Se usó ChatGPT para comprender Gobuster, interpretar resultados, decodificar la nota y reunir los fragmentos.

8. Obtención de la FLAG o resultado

Al unir n4d4, 3st4 y 0cult0 con guiones bajos se obtuvo la FLAG registrada en la resolución. No se conserva evidencia independiente de su aceptación.

```
FLAG{n4d4_3st4_0cult0}
```

9. Análisis del proceso

La estrategia más efectiva fue enumerar por etapas y leer el cuerpo de las respuestas. Al principio se usó /DIRECTORIO/ literalmente y se consultó status.json como si fuera un hallazgo, aunque eran ejemplos. Esas pruebas no aportaron datos. Aprender a interpretar rutas reales y códigos HTTP permitió continuar.

10. Análisis ético

La enumeración debe mantenerse en localhost:8080, como exige el reto. Se respeta la regla de resolver desde fuera y no abrir la imagen Docker. Fuera del laboratorio, estas técnicas requieren autorización y un alcance definido.

11. Conclusiones

Gobuster permitió orientar la búsqueda y reunir los tres fragmentos. El aprendizaje principal fue revisar las respuestas y continuar la enumeración dentro de las rutas encontradas, sin descartar un recurso solo por un código 403.

Fuentes y archivos de respaldo

Pauta_Resolucion_Desafio_CTF.docx: estructura del informe.

Desafio - Gobuster/ENUNCIADO.md: alcance, reglas y objetivo.

Desafio - Gobuster/resolucion.md: comandos, dificultades y fragmentos registrados.